

SOFTWARE REQUIREMENTS SPECIFICATION
SECURITY REQUIREMENTS DOCUMENT (SRS-Sec)

Sistem Booking Hotel

Secure Software Engineering · Teknik Informatika · Universitas Palangka Raya

1. Deskripsi Sistem

1.1 Gambaran Umum

Sistem Booking Hotel adalah aplikasi berbasis website yang memungkinkan pengguna (tamu) melakukan pencarian kamar, reservasi, dan pembayaran secara online. Sistem ini dibangun menggunakan:

Komponen	Teknologi
Frontend	HTML, CSS, JavaScript (browser)
Backend	PHP
Database	MySQL
Integrasi Eksternal	Payment Gateway

1.2 Pengguna Sistem

Pengguna	Peran
Tamu (User)	Melakukan registrasi, login, pencarian kamar, booking, pembayaran, melihat riwayat booking
Admin	Mengelola data kamar, mengelola booking, melihat laporan transaksi

1.3 Alur Data

1. Tamu (User):

- Login dengan kredensial (email, password) → Sistem memvalidasi → Status login (berhasil/gagal)
- Pencarian kamar (tanggal, tipe kamar) → Sistem mengambil info kamar (ketersediaan, harga) → Hasil pencarian
- Rincian booking (tamu, tanggal, metode pembayaran) → Sistem mencatat detail booking → Konfirmasi booking (ID booking)
- Informasi pembayaran → Sistem memproses dan merekam transaksi → Status pembayaran (e-voucher, tanda terima)

2. Admin:

Mengelola data pengguna, update ketersediaan kamar, melihat detail booking, merekam transaksi

1.4 Batasan Sistem

- Sistem TIDAK BOLEH menyimpan data kartu kredit (CVV, PAN)
- Wajib menggunakan HTTPS/TLS 1.2+
- Wajib menerapkan RBAC (2 peran: Tamu, Admin)
- Wajib melakukan logging event keamanan

2. Identifikasi Aset Kritis

Berdasarkan DFD dan komponen sistem, berikut aset kritis yang wajib dilindungi:

ID Aset	Nama Aset	Lokasi	Tingkat Risiko	Alasan Kritis
A-001	Kredensial login (email, password hash)	Database, proses autentikasi	KRITIS	Kebocoran → akun dapat diambil alih
A-002	Data pribadi tamu (nama, email, telepon, alamat)	Database tamu	KRITIS	Privasi pengguna; perlindungan regulasi
A-003	Data booking (kamar, tanggal, harga, status)	Database booking	TINGGI	Manipulasi → double booking, kerugian
A-004	Data transaksi pembayaran (status, referensi, jumlah)	Database transaksi	KRITIS	Target fraud; terkait pendapatan hotel
A-005	Session token (cookie/session ID)	Proses manajemen sesi	TINGGI	Hijacking → akses tanpa kredensial
A-006	Database (keseluruhan)	Server database	KRITIS	Data breach menyeluruh
A-007	File konfigurasi (config.php, .env)	Server backend	KRITIS	Exposure → kredensial database terbuka

A-008	Log sistem & audit trail	Database / file log	TINGGI	Forensik dan deteksi insiden
-------	--------------------------	---------------------	--------	------------------------------

3. Security Requirements

3.1 Autentikasi

ID	Requirement	Verifikasi
AUTH-01	Password HARUS minimal 8 karakter, mengandung huruf besar, huruf kecil, angka	Uji coba registrasi dengan password lemah → ditolak
AUTH-02	Password TIDAK BOLEH disimpan plaintext. HARUS di-hash dengan bcrypt (cost ≥ 10)	Periksa isi database → kolom password berisi hash, bukan plaintext
AUTH-03	Sistem HARUS mengunci akun sementara selama 15 menit setelah 5 kali login gagal	Simulasi 5x login gagal → akun terkunci
AUTH-04	Session HARUS memiliki timeout otomatis setelah 30 menit tidak aktif	Login, diamkan 30 menit, coba akses halaman → harus login ulang

3.2 Otorisasi (RBAC)

ID	Requirement	Verifikasi
RBAC-01	Sistem HARUS menerapkan RBAC dengan 2 peran: Tamu dan Admin	Uji coba akses halaman admin sebagai tamu → ditolak (403)
RBAC-02	Admin HARUS memiliki akses penuh ke data booking, kamar, dan laporan; Tamu HANYA dapat mengakses data sendiri	Login sebagai tamu, coba akses booking milik orang lain → ditolak

3.3 Keamanan Data

ID	Requirement	Verifikasi
DATA-01	Semua komunikasi antara browser dan server HARUS menggunakan HTTPS/TLS 1.2+	Gunakan browser devtools → semua request menggunakan HTTPS
DATA-02	Data sensitif (password, informasi pembayaran) TIDAK BOLEH muncul di URL atau log	Periksa log server dan browser → tidak ada data sensitif dalam bentuk plaintext
DATA-03	File konfigurasi (koneksi database, API key) HARUS disimpan di environment variable (.env), TIDAK BOLEH di-hardcode	Periksa repository → tidak ada kredensial dalam source code

3.4 Validasi Input & Anti-Serangan

ID	Requirement	Verifikasi
INPUT-01	Semua input pengguna HARUS divalidasi di sisi server untuk mencegah SQL Injection	Uji coba input ' OR '1'=1 pada form pencarian → tidak menghasilkan data tidak sah
INPUT-02	Sistem HARUS menerapkan sanitasi output untuk mencegah XSS	Uji coba input <script>alert('XSS')</script> → tidak dieksekusi saat ditampilkan

3.5 Keamanan Pembayaran

ID	Requirement	Verifikasi
PAY-01	Sistem TIDAK BOLEH menyimpan data kartu kredit (nomor kartu, CVV, expiry)	Periksa skema database → tidak ada kolom untuk CVV/PAN
PAY-02	Setiap transaksi pembayaran HARUS melalui payment gateway terpercaya dengan verifikasi signature	Simulasi callback palsu tanpa signature → ditolak

3.6 Logging & Monitoring

ID	Requirement	Verifikasi
LOG-01	Sistem HARUS mencatat event keamanan: login (berhasil/gagal), booking, pembayaran, akses admin	Lakukan aksi-aksi tersebut → verifikasi log tercatat dengan timestamp
LOG-02	Sistem TIDAK BOLEH menampilkan detail error ke pengguna (hanya "Terjadi kesalahan")	Simulasi error → user tidak melihat stack trace atau detail teknis

3.7 Manajemen Dependensi

ID	Requirement	Verifikasi
DEP-01	Library dan dependency HARUS menggunakan versi terbaru yang aman (tidak ada CVE kritis)	

4. Definisi Stakeholder & Trust Boundary

4.1 Stakeholder

No	Stakeholder	Peran & Kepentingan Keamanan
1	Tamu (User)	Pengguna akhir. Kepentingan: kerahasiaan data pribadi, keamanan transaksi pembayaran
2	Admin	Pengelola sistem. Kepentingan: integritas data booking, akses kontrol yang ketat
3	Payment Gateway	Sistem eksternal untuk pemrosesan pembayaran. Prinsip: sistem hotel tidak menyimpan data kartu kredit
4	Developer	Tim pengembang. Bertanggung jawab atas keamanan kode dan

		konfigurasi. Tidak boleh akses data production
--	--	--

4.2 Trust Boundary

Berdasarkan DFD Level 0, berikut trust boundary pada sistem:

Boundary ID	Antara Zona	Mekanisme Keamanan
TB1	User (Browser) ↔ Web Server	HTTPS/TLS, validasi input, rate limiting, anti-XSS
TB2	Web Server ↔ Backend (PHP)	Autentikasi session, validasi request, CSRF protection
TB3	Backend ↔ Database (MySQL)	Parameterized query (prepared statement), kredensial terpisah, enkripsi data sensitif
TB4	Backend ↔ Payment Gateway	mTLS, whitelist IP, signature verification setiap payload